Segurança em Redes de Computadores

Heron Aragão Monteiro

Segurança em Redes de Computadores

Livro texto

Redes de Computadores e a Internet
(Uma abordagem top-down)

James F. Kurose e Keith W. Ross
6ª edição
Pearson Education do Brasil
2013

Segurança de LANs sem fio e Redes de Celulares 4G/5G

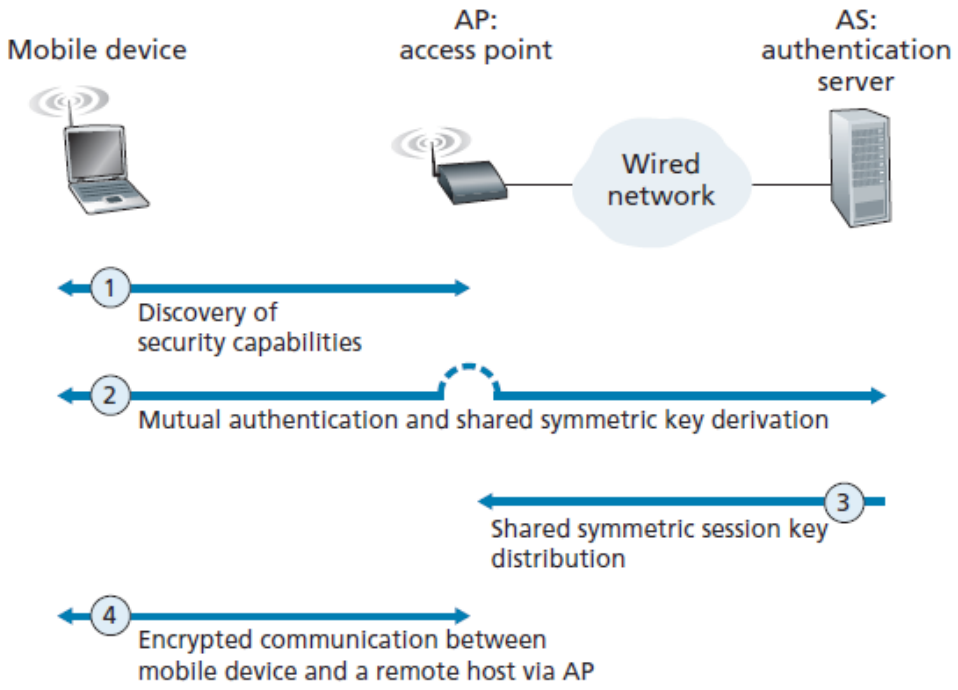
- Autenticação e acordo de chave em LANs sem fio 802.11
  - São duas principais preocupações críticas de segurança que desejamos que uma rede 802.11
    - Autenticação mútua
      - Usada para verificar a identidade do dispositivo móvel conectado à rede e para verificar os privilégios de acesso desse dispositivo
      - Usada também quando o dispositivo móvel deseja autenticar a rede à qual está se conectando
        - Para ter certeza de que a rede à qual está ingressando é realmente a rede à qual deseja se conectar

Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação e acordo de chave em LANs sem fio 802.11
  - São duas principais preocupações críticas de segurança que desejamos que uma rede 802.11
    - Criptografia
      - Necessária porque os quadros 802.11 serão trocados através de um canal sem fio que pode ser detectado e manipulado por potenciais malfeitores
      - A criptografia dos quadros ocorre em nível de link que transportam dados, em nível de usuário, trocados entre o dispositivo móvel e o ponto de acesso (AP)
      - É usada a criptografia de chave simétrica porque a cifragem e decifragem devem ser realizadas em altas velocidades
      - O dispositivo móvel e o AP devem derivar as chaves simétricas a serem usadas

Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação e acordo de chave em LANs sem fio 802.11



Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação e acordo de chave em LANs sem fio 802.11
  - O servidor de autenticação (AS) é responsável por autenticar o dispositivo móvel
    - Ele pode estar localizado no AP
      - Porém é mais comum estar separado
    - É implementado como um servidor que fornece serviços de autenticação
  - Para autenticação, o AP serve como um dispositivo de passagem, retransmitindo mensagens de autenticação e derivação de chave entre o dispositivo móvel e o servidor de autenticação
  - O servidor de autenticação normalmente fornece serviços de autenticação para todos os APs da sua rede

Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação e acordo de chave em LANs sem fio 802.11
  - Fases de autenticação mútua e derivação de chave
    - Descoberta
      - O AP divulga sua presença e as formas de autenticação e criptografia que podem ser fornecidas ao dispositivo móvel
      - O dispositivo móvel solicita as formas específicas de autenticação e criptografia desejadas
      - Õ dispositivo móvel e o AP já estão trocando mensagens, mas o dispositivo ainda não foi autenticado nem possui uma chave de criptografia para transmissão de quadros pelo link sem fio
      - Serão necessárias mais algumas etapas antes que o dispositivo possa se comunicar com segurança através do AP

Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação e acordo de chave em LANs sem fio 802.11
  - Fases de autenticação mútua e derivação de chave
    - Autenticação mútua e derivação de chave simétrica compartilhada
      - Este é o passo mais crítico para “proteger” o canal 802.11
      - O servidor de autenticação e o dispositivo móvel já possuem um segredo comum compartilhado antes de iniciar a autenticação mútua
      - O dispositivo e o servidor de autenticação usarão esse segredo compartilhado, nonces (para evitar ataques de retransmissão) e hashing criptográfico (para garantir a integridade da mensagem) na autenticação mútua
      - Eles também derivarão a chave de sessão compartilhada a ser usada pelo dispositivo móvel e pelo AP para criptografar quadros transmitidos pelo link sem fio 802.11

Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação e acordo de chave em LANs sem fio 802.11
  - Fases de autenticação mútua e derivação de chave
    - Distribuição de chaves de sessão simétrica compartilhada
      - É necessário um protocolo para que o servidor de autenticação informe ao AP a chave de sessão simétrica compartilhada
        - Porque a chave de criptografia simétrica é derivada do dispositivo móvel e do servidor de autenticação
      - Mesmo sendo bastante simples, ainda é uma etapa necessária

Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação e acordo de chave em LANs sem fio 802.11
  - Fases de autenticação mútua e derivação de chave
    - Comunicação criptografada entre o dispositivo móvel e um host remoto através do AP
      - Essa comunicação acontece com os quadros da camada de enlace enviados entre o dispositivo móvel e o AP
        - Que são criptografados usando a chave de sessão compartilhada criada e distribuída pelas Etapas 2 e 3
      - Criptografia de chave simétrica AES é normalmente usada na prática para cifrar/decifrar dados de quadros 802.11

Segurança de LANs sem fio e Redes de Celulares 4G/5G

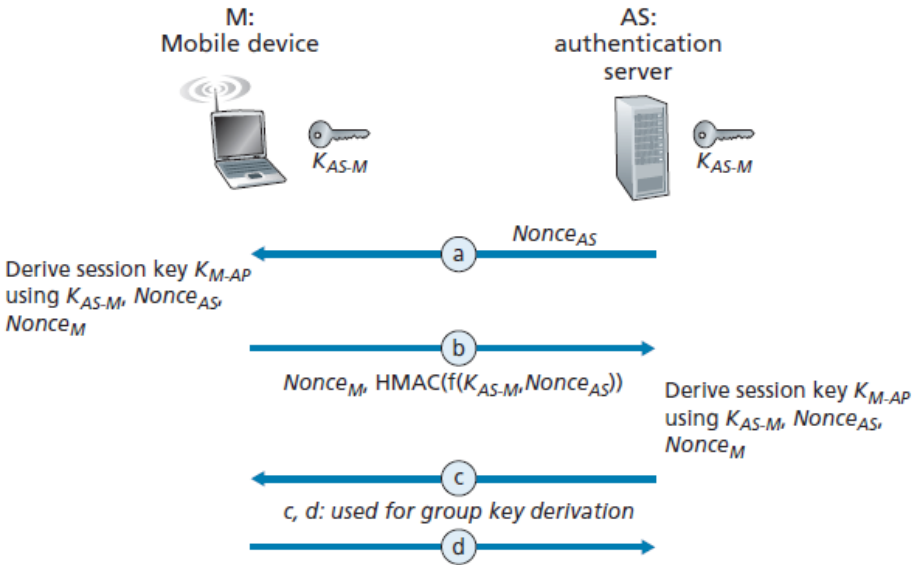
- Autenticação mútua e derivação de chave de sessão simétrica compartilhada
  - A especificação de original de segurança WEP (Privacidade Equivalente com Fio) continha várias falhas de segurança
  - Foi desenvolvido o protocolo WPA1 (Acesso Protegido WiFi)
    - Introduziu no WEP checagem de integridade de mensagens
    - Evitou ataques que permitiam um usuário inferir chaves de criptografia ao observar as mensagens cifradas por algum período de tempo

Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação mútua e derivação de chave de sessão simétrica compartilhada
  - O WPA1 logo deu lugar ao WPA2
    - Que exigia o uso de criptografia de chave simétrica AES
  - O WPA tem um protocolo de handshake de quatro vias

Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação mútua e derivação de chave de sessão simétrica compartilhada
  - O handshake WPA2 de quatro vias



Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação mútua e derivação de chave de sessão simétrica compartilhada
  - O handshake WPA2 de quatro vias
    - O requisito inicial é que o dispositivo móvel (M) e o servidor de autenticação (AS) compartilhem a chave secreta K_{AS-M}
      - Que será usada para derivar a chave de sessão simétrica K_{M-AP}
        - Que, por sua vez, será usada para cifrar/decifrar quadros anteriores transmitidos em M e AP
    - A autenticação mútua e a derivação de chaves são realizadas nos primeiros dois passos (a e b)
    - Os passos seguintes são usados para derivar uma segunda chave para comunicação em grupo

Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação mútua e derivação de chave de sessão simétrica compartilhada
  - O handshake WPA2 de quatro vias
    - Primeiro passo
      - O servidor de autenticação gera o nonce $Nonce_{AS}$ e o envia para o dispositivo móvel

Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação mútua e derivação de chave de sessão simétrica compartilhada
  - O handshake WPA2 de quatro vias
    - Segundo passo
      - O dispositivo móvel
        - Gera seu próprio nonce $Nonce_M$
        - Gera também a chave de sessão simétrica usando os dois nonces, a chave secreta simétrica e os endereços MAC do dispositivo móvel e do servidor
        - Envia seu nonce e um HMAC do nonce do servidor e da chave secreta compartilhada

Segurança de LANs sem fio e Redes de Celulares 4G/5G

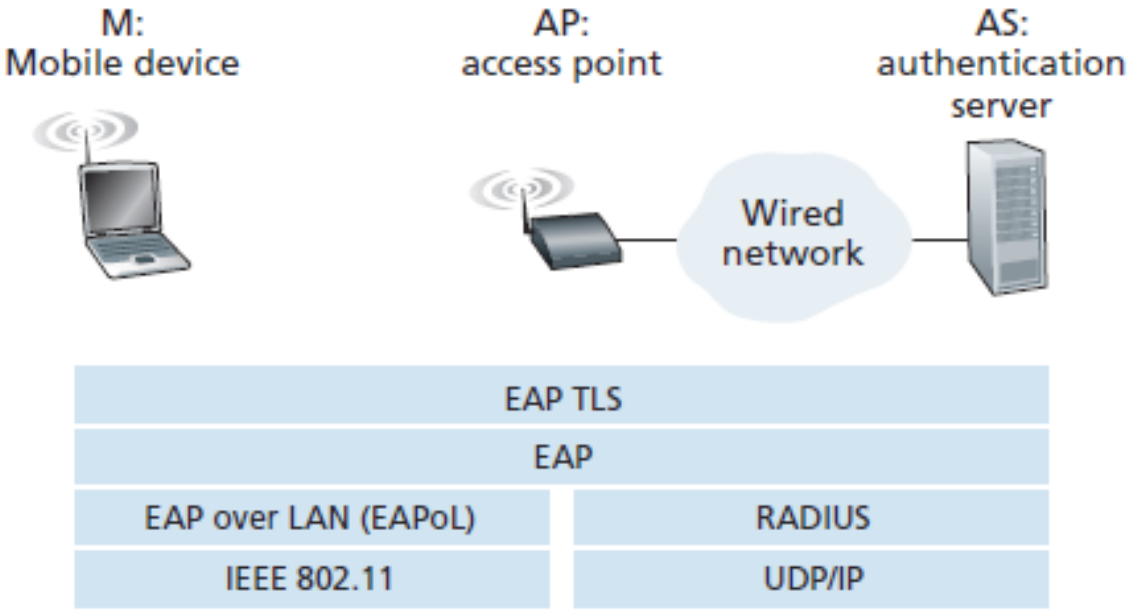
- Autenticação mútua e derivação de chave de sessão simétrica compartilhada
  - O handshake WPA2 de quatro vias
    - Segundo passo
      - O servidor
        - Recebe a mensagem
        - Decifra a mensagem com a chave secreta compartilhada, validando o dispositivo móvel
        - Compara seu $Nonce_{AS}$, verificando que o dispositivo móvel está on-line
        - Calcula também a chave de sessão simétrica
        - Informa ao Access Point (AP) sua chave

Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação mútua e derivação de chave de sessão simétrica compartilhada
  - WAP3
    - Surgiu em junho de 2018 como uma atualização do WAP2
    - Para corrigir uma vulnerabilidade no protocolo do handshake de quatro vias
      - Que poderia induzir o reuso de nonces usados previamente

Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Protocolos de Mensagens de Segurança do 802.11



Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Protocolos de Mensagens de Segurança do 802.11
  - EAP - Extensible Authentication Protocol
    - Define o formato das mensagens fim-a-fim
      - Usados no modo simples de solicitação/resposta da interação entre o dispositivo móvel e o servidor de autenticação
  - As mensagens EAP são encapsuladas usando o protocolo EAPoL (EAP for LAN) e enviadas pelo link sem fio 802.11
  - As mensagens são reencapsuladas usando o protocolo RADIUS para transmissão UDP/IP até o servidor de autenticação
    - O protocolo DIAMETER foi projetado para, no futuro, substituir o protocolo RADIUS

Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação e acordo de chave em redes celulares 4G/5G
  - Muitas das abordagens aqui são paralelas àquelas estudadas nas redes 802.11
    - A exceção é que em redes 4G/5G os dispositivos móveis podem ser conectados à uma rede doméstica
      - Rede da operadora de celular à qual estão conectados
    - Ou podem estar em roaming numa rede visitada
      - As redes visitada e a doméstica precisarão interagir ao autenticar um dispositivo móvel e gerar chaves de criptografia

Segurança de LANs sem fio e Redes de Celulares 4G/5G

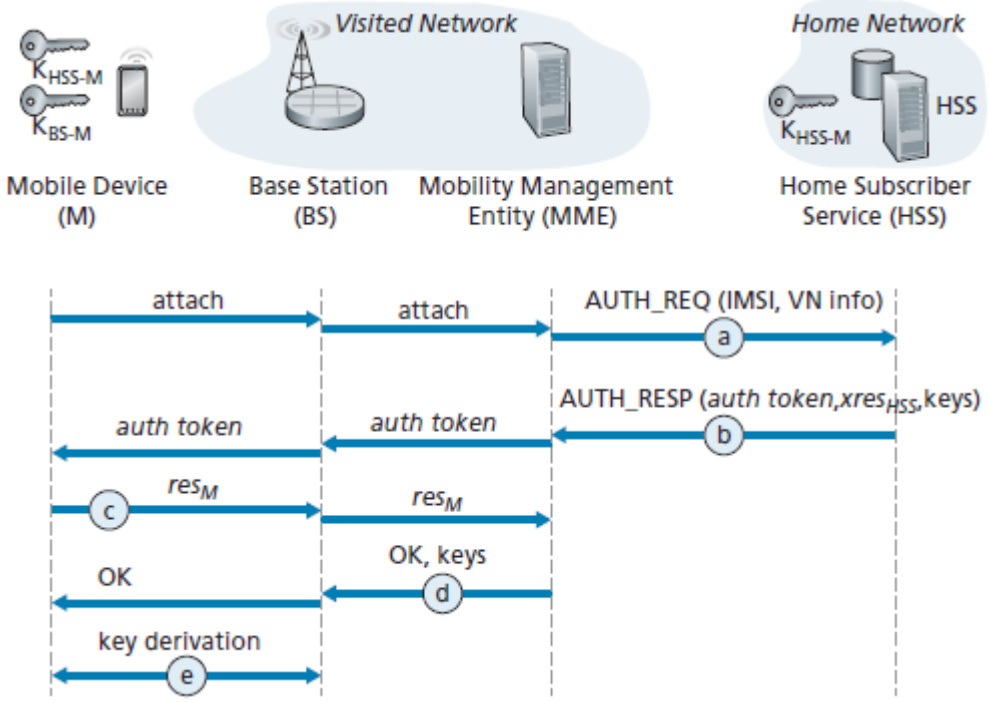
- Autenticação e acordo de chave em redes celulares 4G/5G
  - Os objetivos da autenticação mútua e da geração de chaves são os mesmos na configuração 4G/5G e na configuração 802.11
  - Para criptografar o conteúdo dos quadros transmitidos pelo canal sem fio, o dispositivo móvel e a estação base precisarão derivar uma chave de criptografia simétrica compartilhada

Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação e acordo de chave em redes celulares 4G/5G
  - A rede à qual o dispositivo móvel está conectado precisará autenticar a identidade do dispositivo e verificar os seus privilégios de acesso
    - O dispositivo móvel também desejará autenticar a rede à qual está conectado, apesar dessa autenticação não ser tão óbvia
      - Há casos documentados de malfeitores que operam estações base celulares desonestas que atraem dispositivos móveis desavisados a se conectarem à rede não autorizada, expondo um dispositivo a uma série de ataques
      - Um dispositivo móvel deve ter muito cuidado ao conectar-se a uma rede celular

Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação e acordo de chave em redes celulares 4G



Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação e acordo de chave em redes celulares 4G
  - Solicitação de autenticação para HSS (Home Subscriber Service)
    - Quando o dispositivo móvel solicita pela primeira vez, através de uma estação base, para se conectar à rede, ele envia uma mensagem de anexo contendo sua identidade de assinante móvel internacional (IMSI) que é retransmitida para a Entidade de Gerenciamento de Mobilidade (MME)
    - O MME enviará o IMSI e informações sobre a rede visitada (“informações VN”) para o HSS na rede doméstica do dispositivo

Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação e acordo de chave em redes celulares 4G
  - Resposta de autenticação do HSS
    - O HSS executa operações criptográficas usando a chave secreta $K_{HSS\text{-}M}$, compartilhada antecipadamente, para derivar um token de autenticação, auth_token, e um token de resposta de autenticação esperado, $xres_{HSS}$
    - O auth_token contém informações criptografadas pelo HSS usando $K_{HSS\text{-}M}$
      - Permitirá ao dispositivo móvel saber que quem calculou o auth_token conhece a chave secreta

Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação e acordo de chave em redes celulares 4G
  - Resposta de autenticação do HSS
    - Token de resposta de autenticação esperado – $xres_{HSS}$
      - Contém um valor que o dispositivo móvel precisará ser capaz de calcular usando $K_{HSS\text{-}M}$
      - O valor calculado deve ser retornado ao MME
        - Para provar que o dispositivo móvel conhece a chave secreta, autenticando assim o dispositivo móvel para o MME
    - O MME desempenha apenas um papel de intermediário
      - Ele recebe a mensagem de resposta de autenticação, mantendo o $xres_{HSS}$ para uso posterior
      - Extraindo o token de autenticação e o encaminha para o dispositivo móvel
      - Ele não precisa saber, e não aprenderá, a chave secreta, $K_{HSS\text{-}M}$

Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação e acordo de chave em redes celulares 4G
  - Resposta de autenticação do dispositivo móvel
    - O dispositivo móvel recebe auth_token
    - Verifica se $K_{HSS\text{-}M}(K_{HSS\text{-}M}(IMSI)) = IMSI$
      - Para autenticar HSS
    - Calcula um valor res_M
      - Usando sua chave secreta para fazer exatamente o mesmo cálculo criptográfico que o HSS fez para calcular $xres_{HSS}$
    - Envia esse valor para o MME

Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação e acordo de chave em redes celulares 4G
  - Autenticação de dispositivo móvel
    - O MME compara o valor de res_M calculado pelo celular com o valor de $xres_{HSS}$ calculado por HSS
      - Se corresponderem, o dispositivo móvel é autenticado
    - O MMS informa à estação base e ao dispositivo móvel que a autenticação mútua foi concluída e envia as chaves da estação base que serão utilizadas na próxima etapa

Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação e acordo de chave em redes celulares 4G
  - Derivação da chave do plano de dados e do plano de controle
    - O dispositivo móvel e a estação base determinarão, cada um, as chaves usadas para cifrar/decifrar suas transmissões de quadros através do canal sem fio
    - Chaves separadas serão derivadas para transmissões de quadro de plano de dados e plano de controle
  - O algoritmo de criptografia AES também é usado em redes 4G/5G

Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação e acordo de chave em redes celulares 5G
  - Na rede 4G é o MME na rede visitada que toma a decisão de autenticação
  - Na rede 5G é permitido que os serviços de autenticação sejam fornecidos pela rede doméstica
    - A a rede visitada desempenha um papel de intermediário ainda menor
    - Embora ela ainda possa rejeitar uma autenticação de um dispositivo móvel
  - Cabe à rede doméstica aceitar o pedido de autenticação neste novo cenário

Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação e acordo de chave em redes celulares 5G
  - Além do protocolo de autenticação e acordo de chave (AKA) na rede 4G, A rede 5G aceita dois novos protocolos para autenticação e acordo de chave
    - AKA'
      - Ele também usa a chave secreta compartilhada antecipadamente, $K_{HSS\text{-}M}$
      - Mas como é usado o protocolo EAP no contexto da autenticação 802.11, o 5G AKA' tem fluxos de mensagens diferentes do 4G AKA
    - O segundo protocolo destina-se a um ambiente IoT e não requer uma chave secreta compartilhada antecipadamente

Segurança de LANs sem fio e Redes de Celulares 4G/5G

- Autenticação e acordo de chave em redes celulares 5G
  - Uma mudança adicional no 5G é a utilização de técnicas de criptografia de chave pública para criptografar a identidade permanente de um dispositivo (IMSI)
  - Para que nunca seja transmitida em texto não criptografado